Sicurezza di rete – Attacchi di base

Laboratorio del corso "Sicurezza dei sistemi informativi" (01UDUYG)
Politecnico di Torino – A.A. 2026/27
Prof. Cataldo Basile

Preparata da:
Davide Colaiacomo (davide.colaiacomo@polito.it)

v. 1.4 (06/10/2026)

Indice

1 Scansione degli host **3**

1.1 Network scanning 3

1.2 Port scanning 4

1.3 Identificazione dei servizi 6

1.4 Challenge 6

2 Cattura del traffico **7**

2.1 Man-in-the-middle 7

2.2 Sniffing 8

3 Approfondimenti ed ulteriori esercizi (opzionali) **10**

3.1 DNS spoofing 10

Scopo dell'esercitazione

La crescente dipendenza dei sistemi informativi da Internet e, più in generale, dalle reti, porta in primo piano il problema della sicurezza informatica. Sebbene gli attacchi più sofisticati ed innovativi possano essere effettuati principalmente da persone con grande esperienza, grandi motivazioni e budget, dimostreremo in questa esercitazione che, con programmi liberamente disponibili e poche nozioni di base, si possono creare delle situazioni potenzialmente molto pericolose.

ATTENZIONE

Alcune delle operazioni proposte costituiscono un reato. Lo scopo di questo documento è presentarle ai soli fini didattici. Agli studenti è richiesto di svolgerle solo sui PC del laboratorio ed eventualmente su PC di loro proprietà. Gli autori declinano ogni responsabilità per le azioni compiute al di fuori del suddetto contesto.

Strumenti di sicurezza

Nel corso di questa esercitazione verranno usati i seguenti strumenti:

Nmap - network e port scanner open-source. Progettato per potere effettuare velocemente la scansione di reti di grandi dimensioni. Permette di scoprire, ad esempio, che tipo di sistema operativo e quali servizi sono attivi sugli host della rete. Disponibile per Linux e Windows.
Home page = https://nmap.org/

Ettercap - tool open-source per attacchi man-in-the-middle e sniffing all'interno di una LAN. Disponibile per Linux e Windows.
Home page = https://ettercap.github.io/ettercap/

Wireshark - tool open source dotato di una ricca interfaccia grafica che consente di catturare il traffico di rete. Disponibile per Linux e Windows.
Home page = https://www.wireshark.org/

Strumenti aggiuntivi

Durante lo svolgimento degli esercizi sarà inoltre richiesto di avviare e terminare alcuni servizi tramite i seguenti comandi:

Apache2 - server web
Per avviare, fermare e riavviare il web server usare il comando:

```
systemctl { start | stop | restart } apache2
```

La configurazione delle porte su cui il server è in ascolto si trova in `/etc/apache2/ports.conf`.

VSFTP - server FTP
Per avviare, fermare e riavviare il server FTP usare il comando:

```
systemctl { start | stop | restart } vsftpd
```

La configurazione della porta su cui il server è in ascolto si trova nel `/etc/vsftpd.conf`.

Per esempio, per impostare la porta su 201 occorre aggiungere o modificare la riga `listen_port=201`.

SSH2 - server SSH
Per avviare, fermare e riavviare il server SSH usare il comando:

```
systemctl { start | stop | restart } ssh
```

La configurazione della porta su cui il server è in ascolto si trova nel `/etc/ssh/sshd_config`.

Prima di avviare il server per la prima volta occorre generare le chiavi dell'host con il comando:

```
ssh-keygen -A
```

Exim - server di posta
Per avviare, fermare e riavviare il mail server usare il comando:

```
systemctl { start | stop | restart } exim4
```

La configurazione delle porte è modificabile nel file `/etc/default/exim4`.

Uso del comando arp

Potete cancellare un indirizzo IP dalla tabella ARP usando il comando `arp` con l'opzione `-d` seguita dall'indirizzo da rimuovere. Per esempio, per cancellare l'indirizzo IP `192.168.1.44`:

```
arp -d 192.168.1.44
```

Se avete la necessità di controllare la tabella ARP (ad esempio, per vedere la corrispondenza tra indirizzo IP e MAC) potete usare l'opzione `-e`:

```
arp -e
```

Uso del comando ip

Il comando `ip` è uno strumento potente per analizzare e manipolare il routing e le politiche di routing di una macchina Linux.

Permette anche di rimuovere tutte le entry della tabella ARP (cosa che il comando `arp` non permette) con la seguente sintassi:

```
ip neigh flush all
```

È spesso utile aggiungere il flag `-s` ripetuto due volte per stampare informazioni dettagliate sull'esito di un comando. Per esempio:

```
ip -s -s neigh flush all
```

Durante l'esercitazione dovrete eseguire comandi che richiedono privilegi di `root`; per questo vi suggeriamo di accedere come utente `root` (password: `toor`) sin dall'inizio.

Uso del comando nc (netcat)

Durante l'esercitazione vi verrà richiesto di connettervi direttamente a servizi TCP senza utilizzare strumenti specifici del protocollo. Per farlo è possibile usare l'utility `nc`. La sintassi del comando è la seguente:

```
nc indirizzo_ip porta
```

Ad esempio per connettersi alla macchina con indirizzo IP 192.168.1.20, in ascolto sulla porta 23 il comando sarà:

```
nc 192.168.1.20 23
```

`nc` consente inoltre di mettersi in ascolto per eventuali connessioni tramite il flag `-l`, ad esempio:

```
nc -l 5555
```

Permette di mettersi in ascolto sulla porta 5555.

In entrambi i casi è possibile terminare l'esecuzione dello strumento tramite la combinazione `CTRL+C`

NOTA

Un rudimentale sistema di messaggistica: provate a realizzare un semplice sistema di messaggistica formando coppie: un membro avvierà `nc` in ascolto su una porta e l'altro vi si connetterà; a quel punto sarà possibile inviare dati testuali tra i due computer.

1 Scansione degli host

1.1 Network scanning

La prima fase di preparazione di un attacco consiste nell'identificazione dei bersagli. La tecnica nota come *network scanning* ha l'obiettivo di ottenere informazioni su quali host di una determinata rete sono attivi e quali invece non lo sono.

Come si realizza in pratica? Qual è il metodo più comune per verificare se un host è raggiungibile?

→

Per quale motivo è sconsigliabile un esercizio di questo genere in una rete monitorata?

→

Una volta individuati i sistemi attivi, si può procedere a determinarne la natura. In particolare, una serie di tecniche note come *network fingerprinting* consente di ottenere informazioni sul sistema operativo di un host remoto. Il principio si basa sulle diverse implementazioni dello stack TCP/IP adottate dai vari sistemi operativi.

Il programma `nmap` è uno scanner di rete molto versatile e potente che consente anche di determinare il sistema operativo remoto tramite TCP/IP fingerprinting. Per una descrizione delle tecniche usate visionare:

```
man nmap
```

Esercizio 1. Formate delle coppie e procedete in questo modo:

1. Alice (vittima) scarica l'archivio `lab01.zip` dal portale della didattica e ne estrae il contenuto in una cartella
2. Alice avvia i servizi eseguendo, all'interno della cartella, i seguenti comandi:

   ```
   chmod +x lab01.sh
   sudo ./lab01.sh run
   ```

   NOTA

   I servizi possono essere arrestati tramite il comando

   ```
   sudo ./lab01.sh clean
   ```

3. Bob (attaccante) prova a effettuare un collegamento TCP (`-sT`) sulla porta 80 (`-p 80`) per ottenere informazioni sul sistema operativo (`-O`) dell'host di Alice:

   ```
   nmap -sT -p 80 -O -v indirizzo_alice
   ```

   ATTENZIONE

   Nel caso in cui si cerchi di ripetere l'esercitazione su dispositivi macOS con piattaforma ARM, l'esecuzione del comando

   ```
   sudo ./lab01.sh run
   ```

   non andrà a buon fine a causa di incompatibilità con l'architettura in uso. È infatti necessario ricreare l'immagine Docker contenuta nel file `lab01.tar`. Per farlo occorre eseguire i seguenti comandi all'interno della cartella `Materiale per Mac ARM`, presente nell'archivio `lab01.zip`:

   ```
   sudo docker build -t lab01 .
   sudo docker save lab01 --output lab01.tar
   ```

   l'archivio `lab01.tar` generato dovrà poi essere spostato nella stessa cartella di `lab01.sh`.

1.2 Port scanning

Dopo aver identificato la natura del bersaglio, resta solo scoprire quali servizi sono attualmente attivi sull'host. La tecnica nota come *port scanning* ha l'obiettivo di ottenere informazioni su quali porte di un determinato host sono aperte e quali invece sono chiuse. Con alcuni accorgimenti si può anche capire quali porte vengono filtrate

da un firewall o da un filtro dei pacchetti. Nmap è uno strumento molto potente che consente diversi tipi di port scanning, con cui per ogni porta si ottengono il nome del servizio noto (se disponibile), il numero della porta, lo stato (open, filtered o closed) e il protocollo. Per una descrizione delle tecniche di port scanning attualmente supportate da Nmap fare riferimento all'omonima sezione all'interno del `man` oppure guardate il sito ufficiale di Nmap:

https://nmap.org/book/man-host-discovery.html

Esercizio 2. Formate delle coppie e procedete in questo modo:

1. Alice (vittima) avvia i servizi tramite i comandi dell'esercizio 1.1, se non lo ha già fatto.
2. Alice verifica che i servizi siano attivi. Quali servizi sono in ascolto? (Provate ad usare `sudo netstat -ltup`).
3. Bob (attaccante) prova a fare una scansione TCP (`-sT`) sulle prime 1024 porte dell'host di Alice (con indirizzo IP *indirizzo_Alice*) usando il comando:

   ```
   nmap -sT -Pn -p 1-1024 -v indirizzo_alice
   ```

Riuscite a scoprire quali servizi la vittima (Alice) ha in esecuzione?

→

NOTA

Le well-known port sono controllate e assegnate dall'IANA (Internet Assigned Numbers Authority), tipicamente utilizzabili solo da processi di sistema (o radice) o da programmi eseguiti da utenti privilegiati (root, admin) per servizi esposti su Internet Maggiori informazioni e le porte assegnate sono disponibili nel RFC-1700 (https://tools.ietf.org/html/rfc1700).

Riuscite a immaginare perché può essere utile evitare il ping sull'host (`-Pn`)?

→

Esercizio 3. Verifichiamo adesso se il report di Nmap corrisponde alla realtà:

1. Bob utilizza il tool ftp per connettersi al servizio identificato come FTP

   ```
   ftp indirizzo_alice
   ```

   NOTA

   Utilizzare `CTRL+C` e in seguito il comando `QUIT` per chiudere la connessione ftp

   Che cosa è successo?

   →

2. Bob, a questo punto, prova a utilizzare il tool `nc` per connettersi allo stesso servizio. Quale comando deve utilizzare? Che cosa accade questa volta?

   →

Quale problema è emerso? Come pensate si possa risolvere?

→

1.3 Identificazione dei servizi

Esercizio 4. Per tentare un'identificazione dei servizi in ascolto sulle porte aperte dell'host del vostro collega, provate a sfruttare l'opzione (`-sV`) di Nmap:

```
nmap -sV -Pn -p 1-1024 -v indirizzo_alice
```

Nmap offre anche il flag `-A` che attiva una scansione più aggressiva. Questa versione esegue più test ed è in grado di fornire maggiori informazioni sulla macchina bersaglio. Lanciate anche il comando seguente per notare le differenze:

```
nmap -A -Pn -p 1-1024 -v indirizzo_alice
```

Per una descrizione dettagliata delle tecniche utilizzate da Nmap per identificare i servizi, fare nuovamente riferimento al `man`.

Perché è generalmente una pessima idea usare l'opzione `-A` rispetto al flag `-sV`?

→

Quali tecniche e strumenti di sicurezza possono essere utilizzati per contrastare i tipi di attacco visti finora?

→

NOTA

Nmap offre il flag `-T` che accetta un parametro intero (da 0 a 6) usato per impostare dei timer interni per le scansioni. Più il valore è basso, più la scansione richiederà tempo, poiché le distanze temporali fra le richieste saranno più ampie. Il beneficio di usare numeri bassi, tuttavia, è che la scansione risulterà più invisibile, generando meno banda anomala rilevabile da eventuali contromisure.
Il valore di default è 3, mentre i valori di 0 e 1 sono usati di solito per effettuare una *IDS evasion*. Per esempio, per effettuare una scansione più discreta di Alice è possibile usare il comando:

```
nmap -T0 -sV -Pn -p 1-1024 -v indirizzo_alice
```

1.4 Challenge

Il server HTTP che Alice sta eseguendo nasconde un segreto: collegati dal browser a `http://indirizzo_alice:80/index.html` e usate gli strumenti visti finora per scoprirlo!

Inserisci qui la flag (una stringa nel formato SSI{flag_di_esempio}, e i passi seguiti per ottenerla:

→

2 Cattura del traffico

2.1 Man-in-the-middle

Ettercap è uno strumento molto versatile per eseguire attacchi man-in-the-middle su una LAN. In particolare, in questo esercizio ci concentriamo sulla tecnica nota come "ARP poisoning".

Per una descrizione dei parametri di ettercap e della sua configurazione:

```
man ettercap
man etter.conf
```

Data la natura dell'attacco, sarà utile utilizzare il comando `arp` per visualizzare il contenuto della cache ARP. Potete accedere alla guida del comando `arp` tramite:

```
man arp
```

Esercizio 5. Formate gruppi di tre host (Alice, Bob e Chuck) e procedete nel modo seguente:

1. Esaminate il funzionamento della rete in condizioni normali: Alice, Bob e Chuck si scambiano dei ping e prendono nota della cache ARP di ciascun host nella Tabella 1.
2. Chuck prova a sniffare il traffico di rete con `wireshark`.
3. Chuck lancia l'attacco, avviando Ettercap nel modo seguente (attenzione ai caratteri "/"):

   ```
   sudo ettercap -T -M arp /indirizzo_alice// /indirizzo_bob//
   ```

   Il programma si avvia in modalità interattiva. Chuck può visualizzare una breve guida premendo `h`. Mentre eseguite il comando, verificate il traffico sniffando i pacchetti sui tre host con `wireshark`.
4. Alice e Bob si scambiano nuovamente dei ping e riempiono la Tabella 2 .

Role	IP Address	MAC Address
Alice		
Bob		
Chuck		

Tabella 1: Cache ARP *prima* dell'attacco.

Role	IP Address	MAC Address
Alice		
Bob		
Chuck		

Tabella 2: Cache ARP *dopo* l'attacco.

Che cosa poteva sniffare Chuck prima dell'attacco?

→

Che cosa riesce a sniffare Chuck dopo l'attacco?

→

Riuscite a dedurre dal traffico sniffato come funziona l'attacco?

→

Cosa vi aspettate sia successo alle cache di Alice, Bob e Chuck? Verificate le vostre ipotesi.

→

Riflettete su questa domanda, riferendovi alla Figura 1: immaginate di sostituire il dispositivo "?" con un *hub*, uno *switch*, un *router* o addirittura *Internet*. Quando è possibile effettuare un attacco man-in-the-middle tramite ARP poisoning e quali sono i suoi effetti?

→

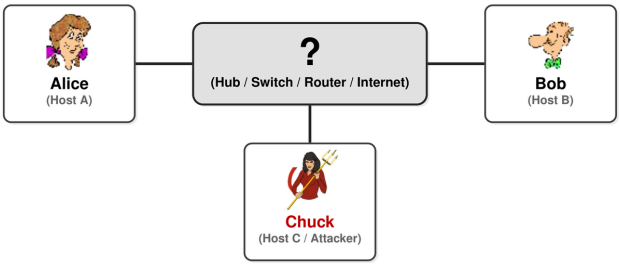


Figura 1: Schema di un attacco man-in-the-middle.

Facoltativamente, verifichiamo come un parametro influenza l'efficacia dell'attacco:

1. Chuck modifica, nel file `/etc/ettercap/etter.conf`, la riga `arp_poison_delay` impostandola a `1000` e riavvia `ettercap`.
2. Bob cancella dalla cache ARP la riga corrispondente all'host di Alice e prova a fare un ping ad Alice.

Che cosa è successo? Che cosa aveva fatto Chuck al punto 1? Che cosa regola la variabile `arp_poison_delay`? Riprovate l'esperimento impostandola a 1 o al valore predefinito (10).

→

2.2 Sniffing

Passiamo ora a sperimentare attacchi passivi. In particolare, lo *sniffing* è un attacco passivo che consiste nel catturare i pacchetti che transitano attraverso la nostra scheda di rete Ethernet impostata in modalità promiscuo. In questo modo tutti i pacchetti che dovrebbero essere ignorati, ossia quelli che non corrispondono all'indirizzo MAC della scheda, vengono invece copiati in un buffer.

Avete già sperimentato questa tecnica negli esercizi precedenti, catturando pacchetti di rete tramite il comando `wireshark`, ma ora ci concentreremo sulla cattura di dati sensibili scambiati all'interno dei protocolli applicativi.

Per simulare attacchi di sniffing useremo ancora `ettercap`, che estrae già username e password dai più comuni servizi (incluso il protocollo FTP). In alternativa, un altro strumento utile a questo scopo è `ngrep` (`http://ngrep.sourceforge.net`), che consente di cercare stringhe predefinite nel traffico catturato, in modo analogo a quanto fa il classico comando `grep` sui file di testo.

Esercizio 6. Lavorate sempre divisi in gruppi di tre host (Alice, Chuck e Bob):

1. Alice si assicura di aver avviato i servizi come specificato al punto 1.2
2. Chuck lancia l'attacco MITM con `ettercap` come nell'esercizio 5.

3. Bob, tramite il browser, raggiunge la pagina di login del sito web di Alice (http://indirizzo_alice:80/login.html) ed "effettua il login" con delle credenziali a suo piacimento

Chuck ha recuperato il nome utente e la password di Bob perché sono stati intercettati da `ettercap` durante la comunicazione HTTP con Alice.

Perché Chuck è riuscito a recuperare queste credenziali? Questo attacco può essere applicato anche a connessioni verso siti web "moderni"?

→

Esercizio 7. Provate ora a estrarre contenuti sensibili dal traffico di posta.

1. Alice si assicura di aver avviato i servizi come specificato al punto 1.2
2. Chuck esegue il comando:

   ```
   sudo ettercap -T -M arp /indirizzo_alice//25 /indirizzo_bob// -e "carta di
   credito"
   ```

3. Bob invia una mail a `alice@kali` con questo messaggio "Ho bisogno di un voto maggiore di 27, il numero della mia carta di credito e' 7865-8993-6282-8282. Faccia lei il prezzo!" usando il client di posta `s-nail`

   ```
   s-nail -S mta=smtp://indirizzo_alice -S 'from=bob@kali' -s "Esame di Sicurezza"
   alice@kali
   ```

   dopo aver digitato il contenuto, premete Invio e poi `Ctrl-D`.

4. Alice può verificare che l'utente `alice` abbia ricevuto il messaggio tramite il comando (non serve perdere tempo a configurare un client di posta per questo semplice controllo):

   ```
   sudo ./lab01.sh read_email
   ```

Osservate attentamente i pacchetti catturati da Chuck.

NOTA

In alcuni casi, l'opzione `-e` di `ettercap` non funziona correttamente con le macchine virtuali. L'ARP poisoning avviene correttamente, ma il modulo di identificazione delle espressioni regolari non riesce a riconoscere le stringhe.

Esercizio 8. Provate ora a spiare la navigazione web:

1. Alice si assicura di aver avviato i servizi come specificato al punto 1.2
2. Chuck abilita l'accesso al display all'utente `root` aprendo un terminale e digitando:

   ```
   xhost +
   ```

3. Chuck, nel menu della Kali, apre le `Default Applications` e come Web Browser predefinito imposta Firefox (se la voce Firefox non compare nel menu a tendina selezionare la voce `Other...` e impostate `/root/firefox/firefox "%s"`).
4. Chuck, lancia `ettercap`, attivando il plug-in `remote_browser`:

   ```
   sudo ettercap -T -M arp /indirizzo_alice//80 /indirizzo_bob// -P remote_browser
   ```

   Nota: la configurazione del plug-in si trova in `/etc/ettercap/etter.conf`.

5. Ora Bob può collegarsi con un browser al server HTTP presente sulla macchina di Alice, ad esempio:

   ```
   http:// indirizzo_alice/
   ```

Chuck può ora verificare la pagina web caricata da Bob nel suo browser.

Come può Chuck intercettare tutto il traffico web di Alice?

→

Come potrebbe essere contrastato questo attacco?

→

Provate ora ad eseguire un login tramite protocollo SSH e catturare username e password: cos'è successo?

→

3 Approfondimenti ed ulteriori esercizi (opzionali)

Attacchi al sistema DNS

3.1 DNS spoofing

In questo esercizio vediamo come applicare tecniche di spoofing al DNS.

> NOTA
>
> In ambiente virtuale o quando il DNS server è presente nella stessa rete di attaccante e vittima, questi test potrebbero non funzionare. Infatti, il successo del DNS spoofing si basa sulla maggiore rapidità di risposta dell'attaccante rispetto a quella del server legittimo. Ad esempio, nella configurazione virtuale proposta che utilizza una NAT Network, lo switch virtuale (un processo software che simula il comportamento di uno switch) è collegato anche a un server DNS che spesso risponde prima di qualsiasi attaccante.

Useremo nuovamente `ettercap` per i nostri scopi. Come al solito, la prima cosa da fare è posizionarci tra la nostra vittima e il suo DNS. A questo punto, `ettercap` si occuperà di "filtrare" le richieste della vittima, rispondendo prima del DNS.

Esercizio 9. Formate gruppi di due host (diciamo Alice, l'attaccante, e Bob, la vittima) e procedete nel modo seguente:

1. Alice aggiunge in `/etc/ettercap/etter.dns` la riga:

   ```
   www.example.com A 130.192.181.193
   ```

2. Bob controlla il contenuto del file `/etc/resolv.conf`.

3. Esaminate il funzionamento della rete in condizioni normali: Bob prova a connettersi ad Internet, ad esempio al sito https://www.example.com/. Osservate direttamente l'interrogazione al DNS con il comando:

   ```
   host -v www.example.com
   ```

   Dovreste vedere le informazioni fornite dal DNS.

→

4. Alice, dopo aver identificato l'indirizzo del gateway (potete usare il comando `route`), avvia l'attacco:

```
sudo ettercap -T -M arp:remote /indirizzo_bob// /indirizzo_gw// -P
dns_spoof
```

5. Bob riprova a connettersi al sito www.example.com.

Cosa vede Bob sul proprio browser?

→

Cosa può essere successo se l'attacco non è andato a buon fine? Fate le vostre ipotesi (e confrontatele con la nota iniziale).

→

Cosa vede Alice nell'output di `ettercap`?

→

Analizzate la configurazione del plug-in DNS, nel file `/etc/ettercap/etter.dns`.
Come può un attaccante ottenere effetti simili a quelli di questo attacco nel caso in cui non si trovi nelle vicinanze della vittima?

→